confidentiality is known as *indistinguishability*. In this game, shown in figure 1.4, the attacker gives the system two equal-length messages, A and B, of their choosing and then the system gives back the encryption of either one or the other of them. The attacker wins the game if they can determine which of A or B was given back to them. The system is said to be secure (for this security goal) if no realistic attacker has much better than a 50:50 chance of guessing correctly. Formal methods can then be used to prove whether a design achieves its security goals.

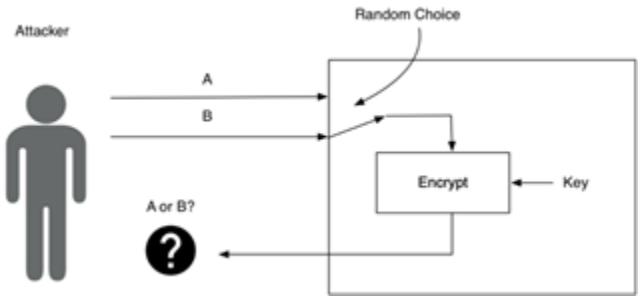


Figure 1.4 The indistinguishability game used to define confidentiality in cryptography. The attacker is allowed to submit two equal-length messages, A and B. The system then picks one at random and encrypts it using the key. The system is secure if no "efficient" challenger can do much better than guesswork to know whether they got back the encryption of message A or B.

Not every scenario can be made as precise as those used in cryptography, and not every project has the time or skills to apply formal methods (although the tools are improving rapidly). An alternative is to refine more abstract security goals into specific requirements that are concrete enough to